

free5GC Result: Frozen vs. Upgraded Report — Decision Summary

Agentic AI for Vulnerability Confirmation and Patch Validation in Open-Source Software

Context. The FYP report was frozen after several rounds of review, with the free5GC case study runtime-confirming one of four reachable handlers (the DELETE subscription handler, CVE-2026-40248) against a minimal harness. Afterward, on a separate branch, that result was extended to a fuller Docker deployment (real MongoDB, real free5GC NRF) and all four reachable handlers were tested. This surfaced a materially stronger finding: the same one-line root cause (a missing `return` after an error response) affects not just DELETE but also both GET variants and PUT, producing a full CRUD bypass rather than a single-record issue. This is now written up as an alternate, upgraded version of the report on that branch, not yet merged.

Version	Strength	Risk / what must be accepted
Frozen (<code>main</code> , <code>commit c58483e</code>)	Stable; already reviewed across multiple rounds; conservative claim.	Only the DELETE handler is runtime-confirmed; the other three reachable handlers remain compile-verified only.
Upgraded (<code>free5gc-full-deployment</code> , <code>commit 9c95480</code>)	All four reachable handlers runtime-confirmed; stronger CRUD-bypass finding (unauthorized read of one record, unauthorized read of the entire collection, unauthorized write, unauthorized delete) all from the same root cause and the same upstream fix; free5GC case becomes a complete, not partial, real-system validation.	Newer, not yet independently reviewed; OAuth2 enforcement was explicitly disabled on the real NRF to make the handlers reachable, and this limitation must be accepted as stated, not overlooked.

What changed technically (for reference). Using the official `free5gc-compose` Docker stack (real, official MongoDB and NRF images) instead of the original minimal stand-in NRF, all three untested handlers were driven through the same malicious/benign request pattern already used for DELETE. Two were found more severe than expected: the collection-level GET returns what looks like a plain 400 rejection but the raw response body is followed by a JSON dump of every stored subscription record; the single PUT returns 404 but the submitted data is genuinely written to storage. All four close cleanly on the patched build, with legitimate use preserved. Full evidence (`manifest.json`, `verdict.json`, raw request/response logs, container logs) is committed under `free5gc_full_deployment/evidence/` on the branch.

Decision needed. Should the report use the conservative, already-reviewed single-handler result (`main`), or the stronger, newer all-four-handler result (`free5gc-full-deployment`)? If the latter, the upgraded PDF becomes the new report base and the frozen version is kept as the prior stable draft. If the former, the all-four-handler result is instead framed as post-report future work.

Prepared as a decision aid; both report versions and the full evidence bundle are available on request.